

GZ: 2023-0.789.858 dated December 11, 2023 (Case Number: DSB-D550.834)

[Note from the editor: Names and companies, legal forms and product designations, addresses (including URLs, IP and email addresses), file numbers (and the like), etc., as well as their initials and abbreviations may have been abbreviated and/or altered for pseudonymization reasons. Obvious spelling, grammar, and punctuation errors have been corrected.]

Criminal Finding

Accused legal entity: C*** Bank AG (FN *3*9*5p)

The accused legal entity based in **** I***stadt, T***platz *2 (hereinafter referred to as "C***B"), has, as the responsible party in accordance with Art. 4 No. 7 of Regulation (EU) 2016/679 on the protection of natural persons in the processing of personal data, on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation, hereinafter: "GDPR"), OJ No. L 119 of May 4, 2016, p. 1 as amended, committed the following administrative offense:

C***B, in its role as the responsible party, during an indeterminate period, but certainly between January 23, 2023, and February 20, 2023, in **** I***stadt, T***platz *2, violated the right of a data subject (Ms. Dr. Luise O***) to information in accordance with Art. 15 GDPR by failing to provide information in the sense of Art. 12 in conjunction with Art. 15 para. 1 GDPR regarding the personal data it processed from the data subject at the time of receipt of the information request dated January 23, 2023, but instead treated this request internally as a request for deletion and subsequently deleted the data. Furthermore, the data subject was only provided with general information. By deleting the data instead of providing information, the data subject's right to information was violated.

Administrative offense according to:

Art. 15 para. 1 in conjunction with Art. 83 para. 1 and 5 lit. b GDPR OJ L 2016/119, p. 1, as amended

Due to this administrative offense, the following penalty is imposed in accordance with Art. 83 GDPR:

Fine of Euro

€ 9,500,-

according to

Art. 83 para. 5 lit. b GDPR OJ L 2016/119, p. 1,

as amended

Furthermore, you are to pay in accordance with § 64 of the Administrative Penal Act 1991 – VStG:

Euro as a contribution to the costs of the penal proceedings, which is 10% of the fine,

but at least 10 Euro;

Euro as reimbursement of cash expenses for

The total amount to be paid (fine/costs/cash expenses) therefore amounts to

Euro

Payment deadline:

If no appeal is filed, this criminal finding is immediately enforceable. The total amount is to be paid within two weeks after the legal force occurs to the account [here shortened] in the name of the Data Protection Authority. Please indicate the business number as well as the date of completion as the purpose of use.

If payment is not made within this period, the total amount may be collected. In this case, a flat-rate cost contribution of five Euro is to be paid. If payment is still not made, the outstanding amount will be enforced.

Reasoning:

1.

The following relevant facts are established based on the conducted evidence procedure:

1.1. A data subject (Ms. Dr. Luise O***) submitted a request for information under Art. 15 GDPR to C***B by letter dated January 23, 2023. The data subject personally handed the request for information to C***B (at a counter in **** I***stadt, T***platz *2).

1.2. There was no response from C***B. The data subject did not receive any information regarding the measures taken in response to her request for information within one month.

1.3. The data subject felt that her right to information was violated and subsequently filed a complaint on February 24, 2023, under Art. 77 GDPR in conjunction with § 24 DSG against C***B with the Data Protection Authority.

1.4. The Data Protection Authority then initiated a complaint procedure for GZ: D124.0368/23 and requested a statement from C***B.

€ 950,-

€ 10,450,-

1.5. On March 2, 2023, the affected person informed the data protection authority via email that she had received a letter from C***B today. In it, C***B confirmed the receipt of her request on January 23, 2023, and furthermore the deletion of her personal data. The affected person could not understand this, as she had not submitted a request for deletion, but rather for information. Specifically, C***B stated in the letter (dated February 20, 2023) the following (note: underlining by the data protection authority): "We received your request for the deletion of your personal data on January 23, 2023. We hereby comply with your request within the one-month period."

1.6. The specific time of the deletion could not be determined. However, the deletion was carried out between January 23, 2023, and February 20, 2023.

1.7. In response to the request for a statement to the data protection authority, C***B announced that, as previously communicated by the affected person, they had complied with the affected person's request for deletion. The accused limited the statement to the fulfillment of the affected person's request for deletion.

1.8. The data protection authority could not verify the deletion and requested C***B to present the specific request for deletion from the affected person.

1.9. C***B subsequently submitted the request for information dated January 23, 2023.

1.10. By decision dated May 17, 2023 (GZ: D124.0368/23 - 2023-0.282.190), the complaint procedure was concluded, and it was established that the affected person was violated in her right to information by C***B, as the request for information from the affected person was not complied with. The decision became final due to the lack of legal remedies.

1.11. The data protection authority subsequently initiated an administrative fine procedure against the accused and requested her, by letter dated July 3, 2023, to justify and disclose her annual turnover.

1.12. After an extension of the deadline was granted, the accused admitted to the alleged act and stated that "the data protection officer responsible for providing information requests" (Mr. Mag. D***) unfortunately "erroneously" assumed that the affected person wanted the deletion of her data and that the data protection officer (hereinafter "DSBA") was also under this misconception during the complaint procedure. The DSBA could not understand why this error occurred on his part. It was difficult for both the accused and the DSBA to understand why the requested information was not provided at least during the course of the complaint procedure to "remedy the violation."

1.13. Regarding the process concerning the handling of rights of affected persons, C***B stated that the DSBA receives these from the respective customer service representatives and processes them within the legal deadline. It was communicated to the affected person that C***B had a business relationship with her, which had to be terminated. In this context, her products (savings books) had to be dissolved. Against this background of contract termination, the DSBA mistakenly assumed that the affected person wanted to assert her right to deletion. The accused herself could not understand why the DSBA was also under this misconception during the course of the complaint procedure.

1.14. In relation to the support of the DSBA, the accused stated that she is currently looking for a full-time employee for "data protection matters." Furthermore, it was decided that external legal advice would be sought for future complaint procedures. If the data protection authority initiates a procedure against C***B in the future, the letter will be forwarded "as an additional external pair of eyes" to the external legal representation. This is intended to prevent similar violations in the future.

1.15. Finally, the accused stated that (in response to the decision in the complaint procedure) information was subsequently provided to the affected person.

1.16. By decision dated August 21, 2023 (GZ: D550.834 / 2023-0.586.049), the DSB suspended the administrative fine procedure in accordance with § 24 VStG in conjunction with § 38 AVG until a final decision by the Court of Justice of the European Union (CJEU) in case C-807/21 (Deutsche Wohnen SE). This suspension decision became final due to the lack of legal remedies.

1.17. By letter dated December 5, 2023, the DSB lifted the suspension decision of August 21, 2023, ex officio and continued the administrative fine procedure - taking into account the judgment of December 5, 2023, of the CJEU in case C-807/21.

1.18. The accused achieved an annual turnover of EUR 98.1*3.4**,43 (operating income - profit and loss statement) in the fiscal year 2022.

2. The findings are made based on the following evaluation of evidence:

2.1. The findings essentially resulted from an examination of the administrative file regarding the above-mentioned complaint procedure as well as from the file components of the administrative fine procedure in question. Furthermore, the accused did not contest the findings made after a request for justification ("The subject of justification is only the amount of the penalty assessment" - point 4.2 of her written justification). The accused admitted to the act and referred to a one-time error of the DSBA.

2.2. The findings regarding the annual turnover (operating income of C***B in the year 2022) are based on the defendant's own statements in the context of their written justification (Point 3.4). Furthermore, the defendant submitted their profit and loss statement for the fiscal year 2022 (Annex 5 to the written justification). There are no doubts about the authenticity and accuracy. The defendant was able to plausibly demonstrate their annual turnover through the submission of Annex 5.

2.3. The findings concerning the business relationship between C***B and the affected party are also based on the defendant's own statements in the context of their written justification (Point 2.3) and are therefore undisputed.

2.4. The relevant facts could thus be established unequivocally and completely based on the existing file situation.

2.5. Only the timing of the deletion could not be established—contrary to the obligation to account for this under Art. 5 para. 2 GDPR—due to a lack of information from the defendant. However, it emerged from the complaint of the affected party and the defendant's response that the deletion was carried out in a period between the receipt of the request for information (23.01.2023) and the response letter from C***B dated 20.02.2023.

3.

Legally, this leads to:

3.1. Regarding the jurisdiction of the Data Protection Authority (DSB) and the scope of the GDPR Art. 83 para. 5 lit. b GDPR stipulates that in the event of violations of the rights of the affected persons according to Arts. 12 to 22 GDPR, fines of up to 20,000,000 Euros or, in the case of a company, up to 4% of its total worldwide annual turnover from the previous fiscal year may be imposed, depending on which amount is higher.

According to § 22 para. 5 DSG, the jurisdiction for imposing fines against natural and legal persons in Austria as the national supervisory authority lies with the DSB.

According to Art. 2 para. 1 GDPR, the regulation applies to the wholly or partially automated processing of personal data as well as to the non-automated processing of personal data that are stored or are intended to be stored in a filing system.

In the present case, there were no indications that the GDPR would not apply. The defendant stated that they processed personal data of the affected party during the course of the business relationship and also after its termination. Regarding the data they processed at the time of the request for information, there was therefore an obligation to provide information. In light of the facts assumed to be proven, the defendant is also to be qualified as the controller according to Art. 4 no. 7 GDPR. The role as the controller was also not disputed by the defendant.

As the controller, the defendant is the addressee of the relevant (penalized) obligations of the GDPR in

connection with the handling and assurance of requests from affected parties in the sense of Art. 12 GDPR, which will be examined in more detail below.

3.2. Regarding the violation of the right to information (objective factual side)

According to Art. 15 para. 1 GDPR, the affected person has the right to request confirmation from the controller as to whether personal data concerning them are being processed; if this is the case, they have the right to information about this personal data. In this context, several pieces of information must be communicated to the affected person (see also Recital 63 GDPR). In accordance with Art. 15 para. 3 GDPR, the controller provides a copy of the personal data that are the subject of the processing.

The right to information under Art. 15 GDPR is the pivot point for the affected person to verify the lawfulness of the processing and, furthermore, to assert the remaining rights of the affected parties. The right to information is constitutionally guaranteed (§ 1 para. 3 no. 1 DSG) and is also enshrined in Art. 8 para. 2 EU-Charter. An affected person is generally only enabled to assert their further rights through the exercise of the right to information (cf. CJEU of 20.12.2017, C-434/16, para. 57). However, the provisions under Art. 15 para. 1 and 2 GDPR only regulate the content of the right to information. Regarding the assurance of the rights of affected parties, the general obligations for controllers are regulated in Art. 12 GDPR.

According to Art. 12 para. 1 GDPR, the controller takes appropriate measures to provide the affected person with all information in accordance with Articles 13 and 14 and all communications in accordance with Articles 15 to 22 and Article 34, relating to the processing, in a precise, transparent, understandable, and easily accessible form, using clear and plain language. According to Art. 12 para. 3 GDPR, the controller must provide the affected person with information about the measures taken in response to the request under Arts. 15 to 22 GDPR without delay, in any case within one month of receiving the request. This period may be extended by a further two months under certain circumstances; however, the affected party must be informed of the extension along with the reasons for the delay within one month.

According to the case law of the DSB, the deletion of personal data (in addition to the disregard of the principle under Art. 5 para. 1 lit. a GDPR) constitutes a violation of the right to information if it is carried out by the controller after the receipt of the request for information (DSB of 27.06.2019, DSB-D124.071/0005-DSB/2019).

In the present case, the accused processed personal data of the affected person for the purpose of the business relationship at the time the request for information was received, and the affected person explicitly and exclusively asserted the right to information in their application dated January 23, 2023. The accused has already violated the affected person's right to information by failing to address their request in accordance with Art. 12 para. 3 GDPR within one month or by not informing them of the measures taken (initially, there was no response from the accused). Only after a complaint was lodged with the data protection authority and a request for a statement was made did the accused send a response letter to the affected person on March 2, 2023, dated February 20, 2023.

However, in the aforementioned response letter from the accused, no information was provided to the affected person in the sense of Art. 12 in conjunction with Art. 15 GDPR, as requested, but rather the (not requested) deletion of their data was confirmed. Furthermore, only general information was provided, and they were referred to "statutory retention periods" (there was also a reference to an attached list of "deletion and retention periods," but this list was neither presented to the affected person nor to the data protection authority during the complaint proceedings). As a result, the accused has violated the affected person's right to information under Art. 15 GDPR.

The objective elements of the administrative offense in question are fulfilled.

3.3. Regarding the criminal liability of the accused as a legal entity

The conditions for the imposition of fines against both natural persons and legal entities are regulated in Art. 83 GDPR. However, the national legislator has further stipulated in § 30 para. 1 and 2 DSG additional "general conditions for the imposition of fines."

According to § 30 para. 1 DSG, the data protection authority may impose fines on a legal entity if

violations of the provisions of the GDPR have been committed by persons who acted either alone or as part of an organ of the legal entity and hold a managerial position within the legal entity due to (1) the authority to represent the legal entity, (2) the authority to make decisions on behalf of the legal entity, or (3) a control authority within the legal entity.

Legal entities can also be held responsible for violations of the provisions of the GDPR according to § 30 para. 2 DSG in cases where a lack of supervision or control by a person mentioned in § 30 para. 1 DSG has enabled the commission of these violations by a person acting for the legal entity (lack of control and supervision), provided that the act does not constitute a criminal offense falling under the jurisdiction of the courts.

The Administrative Court has, in its decision of May 12, 2020, in Ro 2019/04/0229, for the first time addressed the applicability of the conditions for criminal liability under § 30 DSG in a procedure according to Art. 83 GDPR and stated in this context that a legal entity cannot act on its own and therefore its criminal liability under § 30 DSG is a consequence of the factual, unlawful, and culpable behavior of a natural (managerial) person in the sense of § 30 para. 1 DSG. Accordingly, for the effectiveness of the prosecution action directed against the legal entity, a precise description of the act of the natural person (or the so-called "attribution person") is necessary. The attribution of the specific act by the managerial person to the legal entity must be included in the ruling, and the attribution person must also be named as an identified natural person. (cf. VwGH May 12, 2020, Ro 2019/04/0229, with references). In other words: The data protection authority must name in the ruling of the penalty decision that natural (managerial) person whose violation of the GDPR or the DSG is to be attributed to the responsible legal entity in the sense of Art. 4 No. 7 GDPR, in order to subsequently impose a fine under Art. 83 GDPR against the responsible entity as a legal person. This attribution person is to be treated as an accused in the administrative penalty proceedings against the legal entity and has per se party status (cf. Zaczek, The Corporate Liability Model of Art. 83 GDPR, in Jahnel (ed.), Yearbook Data Protection Law 2020, pp. 257 ff).

By decision of December 6, 2021, the Berlin Chamber Court requested the CJEU for a preliminary ruling under Art. 267 TFEU regarding the interpretation of Art. 83 GDPR in relation to the question of whether a company can be directly affected in penalty proceedings due to a violation of Art. 83 GDPR and submitted the following questions in this context:

1. Is Art. 83 para. 4 to 6 GDPR to be interpreted as incorporating the functional concept of a company assigned to Art. 101 and 102 TFEU and the principle of functional responsibility into domestic law, with the result that, under an extension of the underlying legal entity principle of § 30 OWiG, a penalty proceeding can be conducted directly against a company and the imposition of a fine does not require the determination of an administrative offense committed by a natural and identified person, possibly in a full offense?

2. If the answer to question 1 is affirmative: Is Art. 83 para. 4 to 6 GDPR to be interpreted as meaning that the company is liable for a violation committed by an employee?

must have been committed with fault (cf. Art. 23 of Regulation (EC) No. 1/2003 of the Council of December 16, 2002, implementing the competition rules laid down in Articles 81 and 82 of the Treaty), or is an objective breach of duty attributable to it sufficient in principle for the imposition of a fine on the company ("strict liability")? The preliminary ruling request from the Berlin Court of Appeal raised the question of whether the provisions of § 30 para. 1 and 2 of the DSG could even be applied, as they might violate the directly applicable provisions of the GDPR, and whether the statements of the VwGH in its aforementioned ruling on the criminal liability of legal entities in proceedings under Art. 83 GDPR could be upheld. Since the decision of the CJEU on these preliminary questions had a prejudicial effect on the present proceedings, the administrative fine proceedings were suspended.

The CJEU ultimately stated in its judgment of December 5, 2023, that the directly applicable provisions under Art. 58 para. 2 lit. i and Art. 83 para. 1 to 6 GDPR are to be interpreted as being contrary to a national regulation that stipulates that a fine for a violation mentioned in Art. 83 para. 4 to 6 GDPR against a legal entity in its capacity as a controller can only be imposed if that violation has previously been attributed to an identified natural person.

In this context, the CJEU explained that legal entities are liable not only for violations committed by their representatives, directors, or managers but also for violations committed by any other person acting within the scope of the business activity and in the name of the legal entity. Furthermore, it must be possible to impose the fines provided for in Art. 83 GDPR directly against legal entities (cf. CJEU of December 5, 2023, C-807/21, para. 44).

The (material) requirements for the imposition of fines by supervisory authorities are precisely regulated in Art. 83 para. 1 to 6 GDPR, without any discretion for the Member States. The GDPR does not contain any provision stating that the imposition of a fine against a legal entity as a controller depends on the prior determination that this violation was committed by an identified natural person. The GDPR merely grants the Member States the possibility/authority to provide for requirements regarding the procedure to be applied by the supervisory authorities when imposing a fine, but by no means does it allow for the establishment of material requirements that would supplement those in Art. 83 para. 1 and 6 GDPR (cf. CJEU C-807/21, para. 45 et seq.).

The requirements for the imposition of a fine under Art. 83 GDPR by a supervisory authority therefore arise exclusively from Union law. There are no opening clauses in this context for the Member States.

The CJEU pointed out that a national regulation that establishes additional requirements for the imposition of fines under Art. 83 GDPR violates Art. 83 para. 1 GDPR, as it weakens the effectiveness and deterrent effect of fines imposed on legal entities. It must be taken into account that fines are a key element of the GDPR and serve to enforce the objectives of this regulation, ensure the protection of the rights of affected individuals, and guarantee a high level of protection throughout the Union (cf. CJEU C-807/21, para. 51 and 73). As a result, the CJEU concluded that the requirements for the imposition of a fine under Art. 83 GDPR are conclusively regulated in Art. 83 para. 1 to 6 GDPR (para. 53).

3.4. Regarding the subjective aspect of the offense

In relation to the second preliminary question, the CJEU has now explicitly stated, as already assumed by the data protection authority in its previous case law, that only violations of provisions of the GDPR that the controller commits with fault, i.e., intentionally or negligently, can lead to the imposition of a fine (cf. CJEU of December 5, 2023, C-807/21, para. 68).

Regarding the subjective aspect of the offense, it should be noted that the requirement of fault for the imposition of a fine under Art. 83 GDPR is to be interpreted autonomously under Union law and assessed particularly in light of the case law of the CJEU. Also, concerning the preliminary question regarding fault, the CJEU stated that the Member States have not been granted any discretion by the Union legislator for national regulations in this context, as the material requirements are conclusively regulated in Art. 83 para. 1 to 6 GDPR (cf. also CJEU of December 5, 2023, C-683/21, para. 64 et seq.).

Regarding the question of whether a violation was committed intentionally or negligently and can therefore be penalized with a fine, the CJEU clarified in its aforementioned judgment that such fault is already present if the accused could not have been unaware of the unlawfulness of their behavior, regardless of whether they were aware that they were violating the provisions of the GDPR (cf. CJEU C-807/21, para. 76).

Referring to further case law, the CJEU also explicitly clarified that the application of Art. 83 GDPR to legal entities does not require an act or even knowledge on the part of the management body of that legal entity (cf. CJEU of December 5, 2023, C-807/21, para. 77).

The responsibility and liability of a controller extends to any processing of personal data carried out by or on behalf of it. In

In this context, the controller must not only take appropriate and effective measures, but must also be able to demonstrate that its processing activities are in accordance with the GDPR and that the measures it has taken to ensure this compliance are also effective (cf. CJEU C-807/21, para. 38, referring to Recital 74).

Applied to the present case, this means the following:

First, it should be noted that there were no indications during the investigation that the violations in question were committed by a person acting outside the scope of the business activity and on behalf of the legal entity. The accused herself stated that the request for information from the DSBA was processed in the name of the accused. However, as already noted above, it is not the DSBA that is responsible for handling the request, but the accused in her role under Art. 4 No. 7 GDPR (see also Art. 5 para. 2 GDPR).

According to the judgment of the CJEU, it is not necessary for the imposition of a fine against a legal entity that the data protection authority identifies a natural person who acted within the scope of the business activity and on behalf of the legal entity in its decision and attributes the actions of this person to the legal entity. Therefore, in the present case, it is also not relevant whether and which member of the board of the accused (or leader in the sense of § 30 para. 1 DSG) is responsible for the violations in question. In this context, the CJEU explicitly clarified that no action and not even knowledge of the violation on the part of the management body is required for the application of Art. 83 GDPR (para. 77). It can thus remain open whether the board members fulfilled a breach of duty of care towards the DSBA due to objective negligence.

In other words: The culpability of the accused in the present case is assessed based on the behavior of the DSBA, and there is no need for a breach of duty of care by a leader in the sense of § 30 para. 2 DSG to attribute the behavior of the DSBA to the legal entity and to apply Art. 83 GDPR.

In light of the facts assumed to be proven, the data protection authority does not assume any intentional act by the accused. The accused, as the controller, ultimately decided through her DSBA that the request for information would be treated as a request for deletion and that the deletion would subsequently be carried out. The fulfillment of the subjective element of the offense is also not disputed by the accused (see written justification, point 4.3.). She stated that neither she nor the DSBA can comprehend this failure.

During the course of the investigation, there were, in any case, no indications that the accused bore no culpability for the violation of the applicable administrative regulations. The accused could not defend herself in light of the case law of the CJEU.

about the unlawfulness of their behavior, regardless of whether they were aware that they were violating the provisions of the GDPR (cf. CJEU C-807/21, para. 76 and 77; CJEU C-683/21, para. 81 and 82 with references). However, there were no indications of (1) intentional and (2) systematic violations of the right to information. As a result, culpability in the form of negligence (Art. 83 para. 2 lit. b GDPR) is present. Thus, the subjective aspect of the offense is also fulfilled.

4.

Regarding the determination of penalties, the following should be noted:

According to Art. 83 para. 1 GDPR, the data protection authority must ensure that the imposition of fines for violations of the provisions of the GDPR subject to sanctions (Art. 83 para. 4, 5, and 6 GDPR) is effective, proportionate, and deterrent in each individual case. Furthermore, Art. 83 para. 2 GDPR stipulates that when deciding on the imposition of a fine and its amount, certain criteria must be duly considered in each individual case.

In the context of penalty assessment, the data protection authority applied the EDSA guidelines regarding the calculation of fines under the GDPR (cf. EDPB Guidelines 04/2022 on the calculation of administrative fines under the GDPR, Version 2.1 dated 24.05.2023 – hereinafter referred to as "Fines Guidelines").

The
penalty assessment
within
a
statutory
penalty range
is
also

a

discretionary decision that must be made according to the criteria established by the legislator (cf. VwGH 05.09.2013, 2013/09/0106).

According to § 19 para. 1 VStG, the basis for determining the penalty is the significance of the legally protected interest and the intensity of its impairment by the act.

Moreover, according to the purpose of the penalty, the relevant aggravating and mitigating factors, insofar as they do not already determine the penalty, must be weighed against each other. Special attention must be paid to the extent of culpability. Considering the nature of administrative criminal law, §§ 32 to 35 of the Penal Code are to be applied *mutatis mutandis*. The income and asset situation and any care obligations of the accused are to be taken into account when determining fines (this naturally applies only to natural persons but can be applied *mutatis mutandis* to legal entities); however, this only to the extent that the directly applicable provisions of the GDPR do not displace the provisions of the VStG and to the extent that is ordered by Art. 83 para. 8 GDPR and Recital 148 with regard to the procedural guarantees to be provided.

According to Art. 83 para. 5 GDPR, in the case of the violations mentioned therein, in accordance with para. 2, fines of up to EUR 20,000,000 or, in the case of an undertaking, up to 4% of its total worldwide annual turnover of the preceding financial year are imposed, whichever amount is higher. In the present case, the dynamic penalty range of up to 4% of annual turnover does not apply.

The term turnover in Art. 83 para. 4, 5, and 6 GDPR is to be understood in the sense of Art. 2 no. 5 of Directive 2013/34/EU of the European Parliament and of the Council of June 26, 2013, on the annual financial statements, the consolidated financial statements, and related reports of certain types of companies, amending Directive 2006/43/EC of the European Parliament and of the Council and repealing Council Directives 78/660/EEC and 83/349/EEC (hereinafter referred to as "Directive 2013/34/EU"). Turnover is the sum of all goods and services sold. Net turnover is the amount resulting from the sale of products and the provision of services after deducting revenue reductions and value-added tax (VAT) as well as other taxes directly related to turnover (cf. EDPB Guidelines 04/2022 on the calculation of administrative fines under the GDPR, Version 2.1, para. 128 ff).

The accused generated an annual turnover of EUR 98.1*3.4**,43 in 2022 (operating income). Applying the Fines Guidelines, the accused is classified in relation to their turnover and with regard to the imposition of an effective, deterrent, and proportionate fine in the category "Undertakings with a turnover of €50m up until €100m." This classification duly considers the size of the company, particularly to ensure the proportionality of the fine.

In light of the facts assumed to be proven and considering the nature, severity, and duration of the violation (Art. 83 para. 1 lit. a GDPR), the intent or negligence of the violation (Art. 83 para. 2 lit. b GDPR), as well as the categories of personal data affected by the violation (Art. 83 para. 2 lit. g GDPR), the data protection authority determines the severity of the infringement ("Seriousness of the infringement") as having a low level of seriousness ("low level of seriousness"). The accused correctly pointed out in this context that the violation concerned a single natural person. The investigation did not reveal any indications that the violation in question was committed intentionally or systematically by the accused. The accused also acted, as previously stated, negligently.

Regarding the present case, in addition to the criteria already considered for determining the severity according to Art. 83 para. 1 lit. a, b, and g GDPR, the following aggravating factors were taken into account in the penalty assessment:

- n/a (the fact that the accused violated the affected person's constitutionally guaranteed right to information - § 1 Abs. 3 Z 1 DSG; Art. 8 Abs. 2 GRC - has already been taken into account by the DSB in determining the severity - see above).

In relation to the present case, the following mitigating factors were additionally considered in the assessment of the penalty:

- there are no relevant previous violations of the GDPR against the accused at the DSB.
- the accused cooperated in the course of the present investigation procedure before the DSB and thereby contributed to the establishment of the truth, in particular by not disputing the alleged facts, admitting her misconduct, and showing insight after receiving the request for justification.

The accused expressed remorse, and the DSB assumes that she will not commit such a violation of

the rights of an affected person in the future.

- The DSB also does not overlook that after the delivery of the decision in the complaint procedure of the affected person, the accused at least provided information about the remaining (not covered by the deletion) personal data to comply with the DSB's decision and to reduce the infringement of the administratively protected legal interest. This also led to a reduction of the penalty in this specific case, but taking into account that the affected person had to wait several months and had to exercise her right to complain under Art. 77 GDPR in conjunction with § 24 DSG.

In determining the fine, considerations of special prevention and general prevention may also be included according to the consistent case law of the VwGH (see VwGH 15.5.1990, 89/02/0093, VwGH 22.4.1997, 96/04/0253, VwGH 29.1.1991, 89/04/0061). The imposition of the specific fine was not necessary in terms of special prevention to deter the accused from committing further violations.

However, the imposition of the fine was necessary in terms of general prevention to raise awareness among responsible parties regarding their obligations under the GDPR, particularly in connection with the (timely) handling and ensuring of the rights of affected persons in accordance with Articles 12 to 22 GDPR.

The penalty ultimately imposed in the amount of EUR 9,500 therefore appears to be appropriate in relation to the realized value of the offense, measured against the available penalty range of Art. 83 Abs. 5 GDPR (here up to EUR 20,000,000) and the established annual turnover of approximately EUR 98,000,000, and is situated at the lower end of the available penalty range due to the mitigating factors (0.05% of the penalty range). There is no room for a further reduction of the sanction. An (even) lower amount would no longer meet the criteria for a fine as stipulated in Art. 83 Abs. 1 GDPR in the present case.